Figure 3.1 shows the relationships between these terms. As indicated by the dotted line in the figure, the principal and subject are usually the same, but not always, so it's a good idea to be able to distinguish them. For example, a parent who is accessing a system on behalf of their child would be the principal, while the child is the subject.

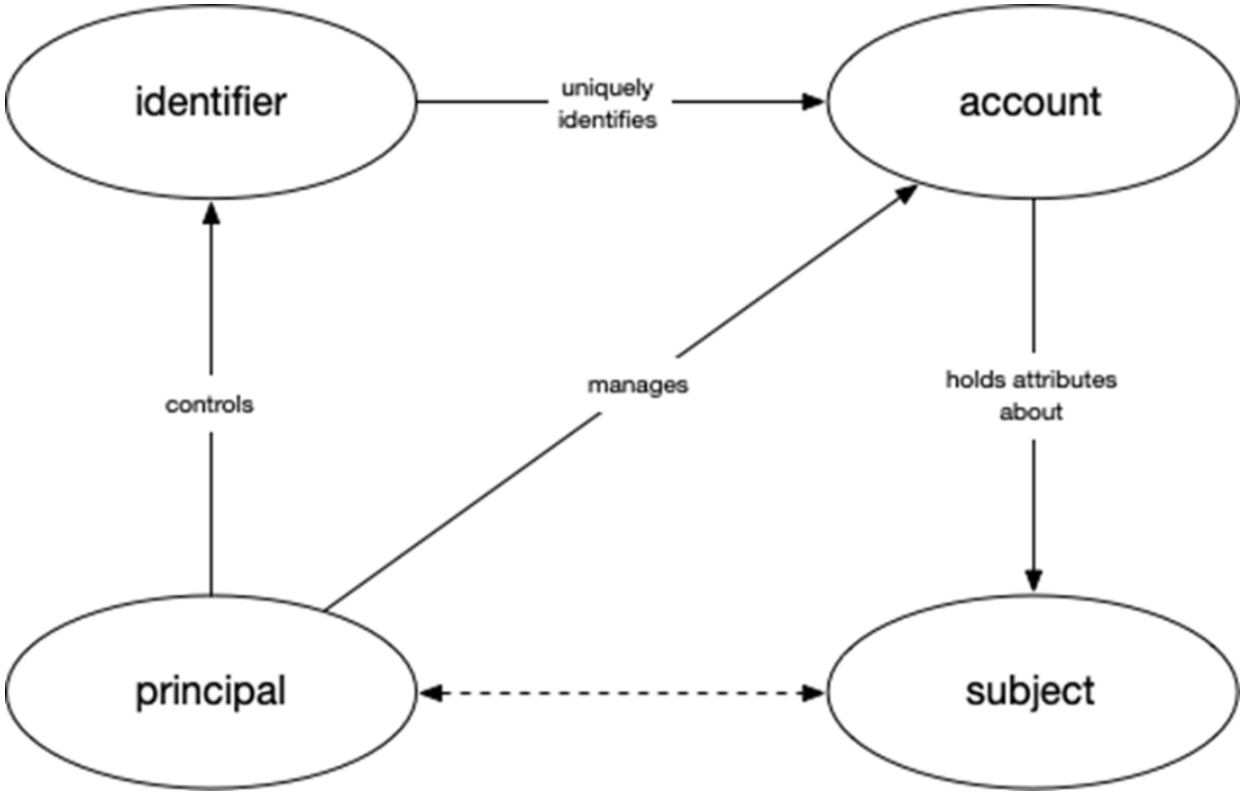


Figure 3.1 Relationships among key identity concepts used in authentication and authorization. A principal (an actor like a user or service) controls an identifier uniquely identifying an account. The account stores attributes about a subject, which might be the principal itself or another entity the principal manages.

We will define many more terms as we continue our exploration of authorization.

3.2 Authentication preserves relationship integrity

Relationship integrity comes down to technical confidence that the entity that established the account is the same entity currently using it. The Twitter hack shows how authentication is necessary to preserve the integrity of the relationship between a system and the people and services that rely on it.